Home Lab Project Week 12, Day 2

Compile the final security analysis report covering the lab architecture, reconnaissance findings, cleartext traffic analysis, exploitation results, vulnerabilities, firewall configuration, and network segmentation.

1. Lab Architecture Overview

The home lab was constructed to simulate an enterprise environment, separating production services from testing and untrusted zones.

- **Hypervisor / Environment:** Hosted on a dedicated Type-1/Type-2 hypervisor (VirtualBox).
- **Endpoints:**
  - **Attacker Node:** Kali Linux (IP: `10.0.10.15`)
  - **Target Node 1 (Linux Server):** Ubuntu Server hosting legacy web applications (IP: `10.0.20.50`)
  - **Target Node 2 (Windows Domain Controller):** Windows Server 2022 (IP: `10.0.20.10`)
- **Core Network Services:** Active Directory Domain Services (AD DS), DNS, DHCP, and an Apache/NGINX web server.

---

2. Reconnaissance Findings

Active and passive reconnaissance identified the active attack surface within the target subnet (`10.0.20.0/24`).

- **Network Scanning (Nmap):** A TCP full-connect and service detection scan (`nmap -sV -sC -p- 10.0.20.50`) revealed several open ports:
  - `Port 21/TCP`: FTP (vsftpd 2.3.4)
  - `Port 80/TCP`: HTTP (Apache 2.4.41)
  - `Port 445/TCP`: SMB (Samba 4.X)

- **OS Fingerprinting:** Identified Target Node 1 as a legacy Linux kernel (Ubuntu) and Target Node 2 as Windows Server 2022 running an Active Directory environment.
- **Directory Brute-Forcing:** `Gobuster` identified an unauthenticated backup directory (`/backup/config.bak`) on the web server.

---

3. Cleartext Traffic Analysis

Using `Wireshark` and `tcpdump` on the monitoring interface, cleartext network traffic was captured to evaluate data-in-transit risks.

- **FTP Credentials Leaked:** Capturing traffic on Port 21 during a mock user login exposed raw, unencrypted authentication strings:
  - `USER: admin`
  - `PASS: P@ssword123!`
- **HTTP Basic Authentication:** The web application lacked TLS/SSL (HTTPS). Communication over Port 80 exposed session tokens and API keys in plain text within the HTTP headers.
- **LLMNR/NBT-NS Broadcasts:** Windows endpoints were observed broadcasting Link-Local Multicast Name Resolution queries, rendering them vulnerable to spoofing tools like `Responder`.

---

4. Exploitation Results

Simulated attacks successfully compromised both target nodes based on flaws uncovered during reconnaissance.

- **Exploit 1: FTP Backdoor Execution (vsftpd 2.3.4):**
  - **Mechanism:** Leveraging a known backdoor in this specific version, sending a username ending in `:)` triggered a root shell listener on port `6200`.
  - **Result:** Successfully spawned a root shell on Target Node 1 (`10.0.20.50`).
- **Exploit 2: Credential Stuffing & Lateral Movement:**
  - **Mechanism:** The credentials harvested from the cleartext FTP analysis (`admin:P@ssword123!`) were reused against the SMB service of the Windows Domain Controller.

- **Result:** High-privilege command execution achieved via `psexec.py`, resulting in local administrator access.

---

5. Vulnerabilities Assessment

The following critical flaws present the highest risk to the lab environment:

Vulnerability ID / Type	Severity	Description	Remediation
CWE-319: Cleartext Transmission	**High**	Sensitive credentials (FTP, HTTP) sent over the wire unencrypted.	Implement SFTP, enforce HTTPS via TLS certificates, and disable legacy protocols.
CVE-2011-2523 (vsftpd Backdoor)	**Critical**	Malicious backdoor code in the application package allows arbitrary command execution.	Upgrade `vsftpd` to a patched release or migrate to a secure alternative like `proftpd`.
CWE-287: Weak Password Reuse	**Medium**	Identical administrative credentials used across completely separate operating systems.	Implement unique local admin passwords using LAPS and enforce strict password complexity.

---

6. Firewall Configuration & Network Segmentation

A dedicated virtual firewall appliance (e.g., pfSense / OPNsense) was introduced to isolate network zones and mitigate lateral movement.

Zone Allocation

- **WAN Zone:** External internet access.
- **Management/Attacker Zone (VLAN 10):** Isolated zone for Kali Linux.
- **Production/Target Zone (VLAN 20):** Contains the web servers and Active Directory structure.

Implemented Firewall Rules Matrix

- **Rule 1 (Block Inbound):** Explicitly deny all traffic originating from VLAN 20 (Production) going into VLAN 10 (Management).
- **Rule 2 (Restricted Inspection):** Allow VLAN 10 to access VLAN 20 strictly on necessary ports (`80`, `445`) for remediation testing, while blocking port `21` and `6200`.
- **Rule 3 (Egress Filtering):** Restrict Target nodes from initiating unmonitored outbound internet connections, mitigating reverse-shell callouts to external Command and Control (C2) servers.

Segmentation Effectiveness

Following the implementation of VLANs and firewall rules, a secondary Nmap scan from the Attacker Node confirmed that previously open, unmitigated ports (like the rogue port `6200`) were successfully filtered and unreachable, verifying the confinement of the blast radius.

To wrap up your Week 12 milestone, what would you like to focus on next?

- **Drafting a formal executive summary** or remediation roadmap based on these findings?
- **Writing the specific configuration scripts** (e.g., pfSense rules or iptables commands) to lock down the lab?
- **Setting up an IDS/IPS** (like Snort or Suricata) to detect these exploits in real-time?